

MXMap Italia

National Observatory for Digital Sovereignty – https://mxmap.it

Fabio Pietrosanti (naif) · SFSCon 2026 · 14 November, Auditorium A2

Hermes Center for Transparency and Digital Human Rights

Who is speaking, and why this exists

The premise

Fabio Pietrosanti (naif) — hacking since '95, security since 2000. Troublemaking for public interests, “professionally a cybersecurity outsider since 2013”.

This project started from one question nobody had answered with data: **who actually operates the digital infrastructure of the Italian state?**

Not who owns the building. Not where the disk sits. Who holds the keys, the control plane, and the legal obligation to comply when a foreign authority asks.



The next decade, and why this is built to last

Here to stay

Measure, permanently. Not a study that ages. An instrument that re-runs itself and publishes the result, every month, with the method public so anyone can redo or dispute it.

Cover the money, and just the machines. Who operates the infrastructure is half the answer. The other half is how much public money buys it, and whose jurisdiction it lands in.

Report annually, as political action. A national account of digital sovereignty, generated from the data, presented where decisions are made.

Hand it over. Open data, open source, open method — so the counting survives us and can be rebuilt in any other European country.

01

The method

Where the numbers come from, and why you can trust them

This is not our idea. It is upstream research.

Credit where it belongs

MXmap — David Huser, mapping how Swiss municipalities host their email and how deeply their DNS is tied to US hyperscalers. Live at mxmap.ch.

SecAssure 2026 — the project grew into a team research effort covering **~15,300 municipalities** in Germany, Austria and Switzerland.

Paper: papers.mxmap-project.org/secassure2026.pdf (accepted manuscript)

Site: secassure2026.mxmap-project.org · Code: github.com/mxmap/secassure2026

MXMap Italia is the Italian adaptation of that work — same method, same code lineage, a different country and a much larger set of public bodies.

We follow upstream rather than fork it: fixes produced by that community reach us instead of ageing in a private copy.

How the technical measurement actually works

Technical core

Stage 1 — resolve domains. Enumerate public bodies from IndicePA, reconcile with other sources, verify candidate domains with MX lookups, score source agreement.

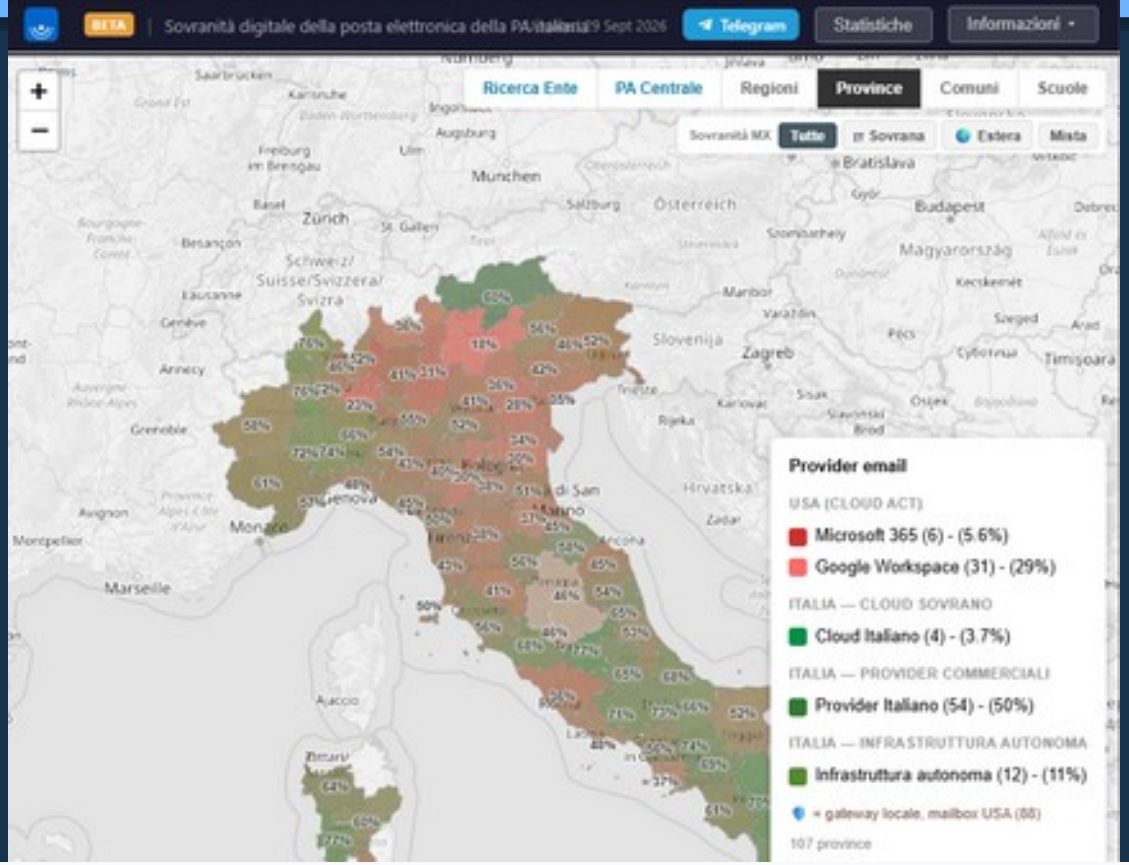
Stage 2 — classify providers. For every domain, resolve all MX hosts, pattern-match, then run concurrent probes: **SPF, DKIM, DMARC, Autodiscover, CNAME chain, SMTP banner, tenant lookup, ASN, TXT verification, SPF IP ranges**.

Weighted evidence → confidence score 0–100. A gateway appliance in front of Microsoft is not Microsoft; a self-hosted server whose DKIM points to Google is Google. The look-through is the hard part, and it is where naive scans get it wrong.

Everything is public DNS. No intrusion, no authentication, no scraping of private systems.



Mxmap.it





Ricerca Ente

Cerca tra tutti gli enti pubblici italiani analizzati. Ogni riga è un ente IndicePA con il suo provider di posta elettronica classificato via DNS pubblico (MX, SPF, DKIM, autodiscover, ASN), con il **livello di attendibilità** della classificazione e la **giurisdizione del server MX** (domestica / estera). Filtra e ordina per nome, codice IPA, categoria, provider, sovranità, attendibilità, giurisdizione, regione. Usa i bottoni di download per scaricare l'intero dataset.

Scarica il dataset completo: CSV | Excel | { } JSON

Licenza dati: ODbL-1.0 + CC-BY-4.0 · Codice: MIT

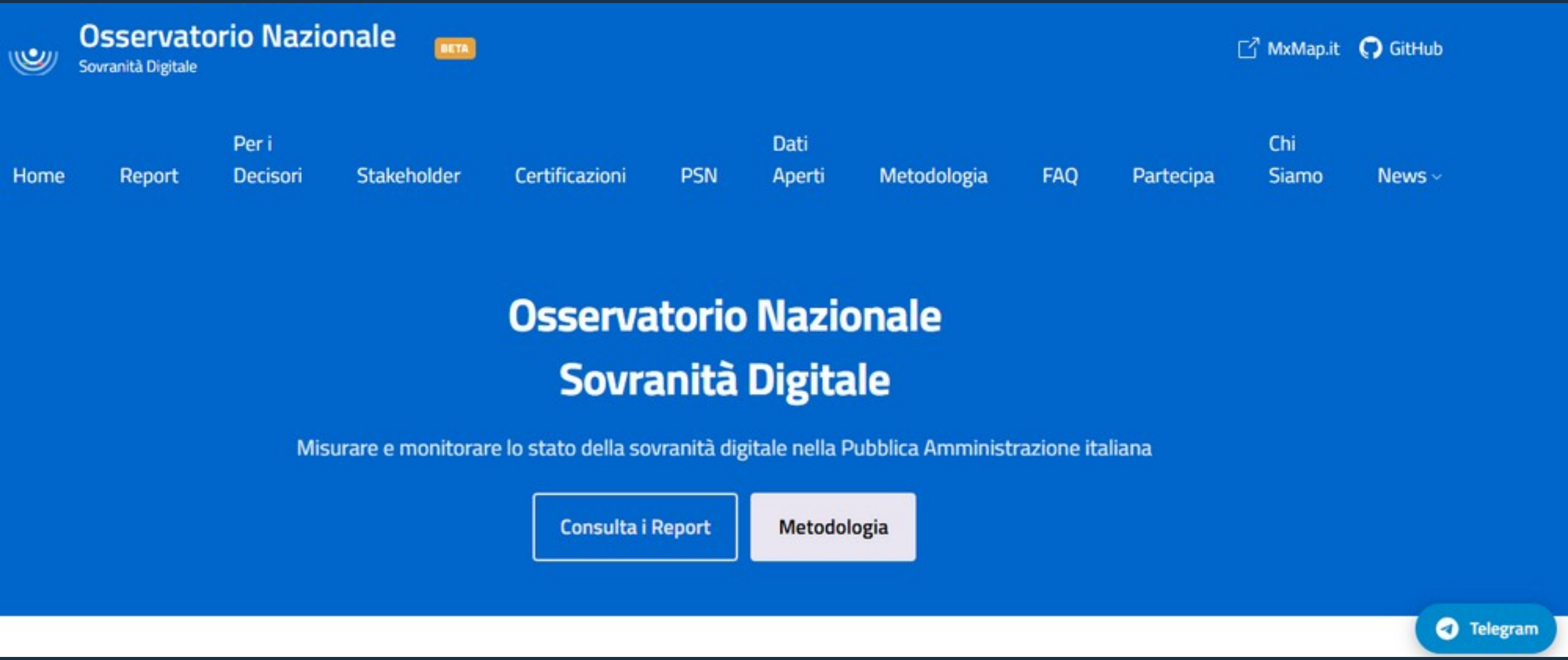
22.900	10.752 (47.0%)	930 (4.1%)	7423 (32.4%)	3037 (13.3%)
ENTI TOTALI	USA (CLOUD ACT)	CLOUD SOVRANO	PROVIDER ITALIANO	INFRASTRUTTURA AUTONOMA

senato | Tutte le categorie | Tutti i cluster | Tutti i provider | Tutte le sovranità | Tutte le giurisdizioni MX | Tutte le attendibilità | Tutte le regioni

1 risultati su 22.900 Reimposta filtri

Codice IPA	Categoria	Ente	Provincia	Dominio	Provider	Sovranità	Attendibilità	Giurisdizione MX	Evidenza
sdr	Avvocatura / Organo costituzionale	Senato della Repubblica	RM	senato.it	Microsoft 365	USA (CLOUD Act)	96%	Estera	MX is cisco-ironport gateway; SPF+DKIM confirm microsoft ⚠ Riporta un errore

Osservatorio.mxmap.it



Ongoing: following the money, not just the machines

In progress — the missing half

Knowing **who operates** the infrastructure is half the answer. The other half is **how much public money buys it, and whose jurisdiction it lands in.**

We are building the second instrument: Italian public spending on cloud services, **year by year**, split between providers under US control and providers in Italy and Europe — automated and re-run like the DNS measurement, on open procurement data.

The sharpest test case is «Cloud Italia» and the PNRR migration funds, allocated to move public administration onto infrastructure officially described as sovereign. Public money, a public sovereignty claim, and an outcome nobody has yet measured in euros.

Status: prototype running, classifier not yet trained, data to be completed via ANAC transparency portals and AgID tools.

Every figure will ship with its method, as the DNS measurement does: reproducible or it does not count.



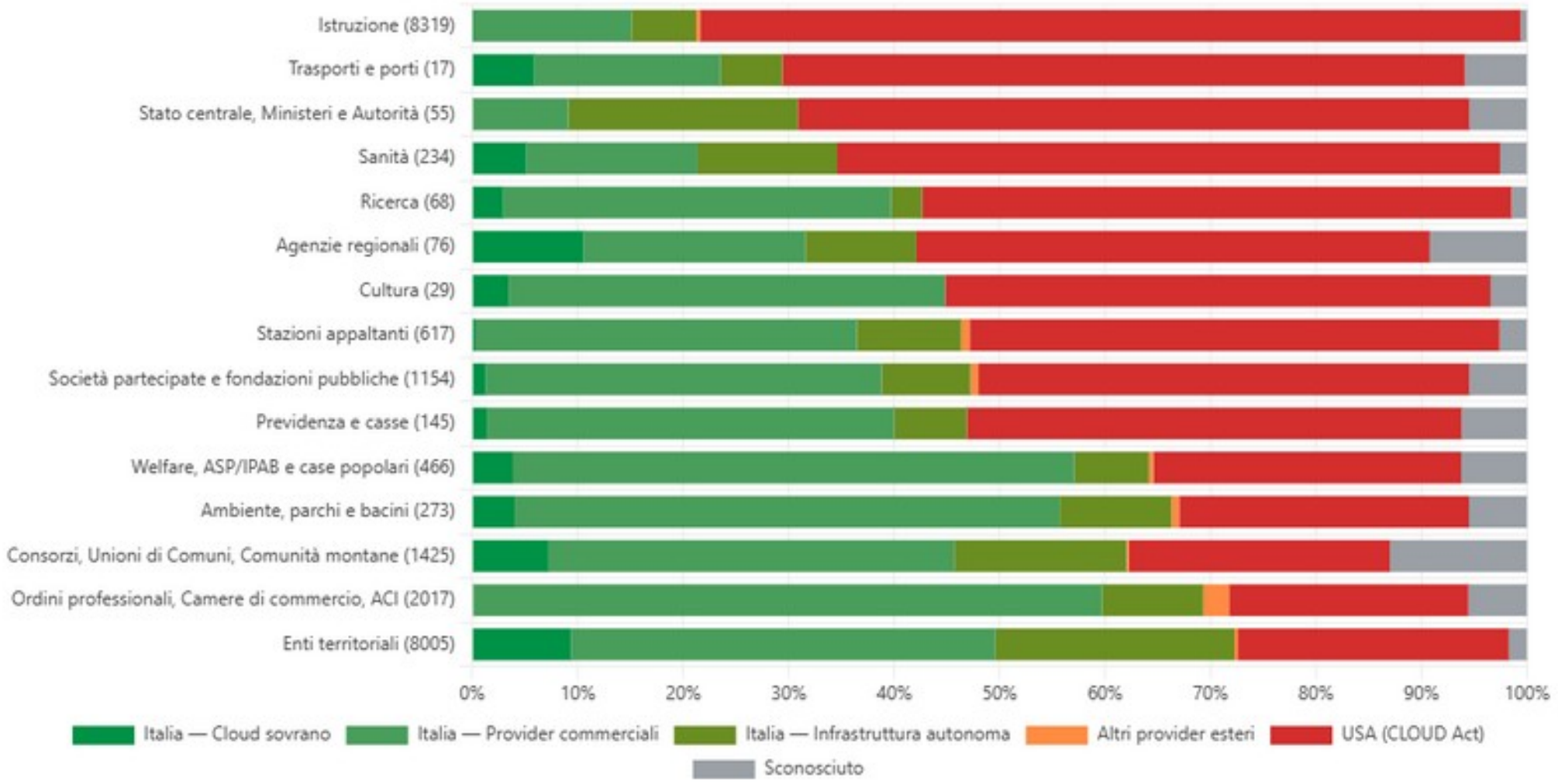
02

The results

22,922 Italian public bodies, 94% coverage

Sovranità per tipo di ente

Composizione della sovranità dentro ogni categoria di PA (ordinate dalla meno alla più sovrana). Le scuole e lo Stato centrale sono i più esposti al CLOUD Act; Comuni e Ordini i più sovrani.



Which companies, concretely

Top providers

Google Workspace — 26.9% of public bodies (6,157)

Microsoft 365 — 16.4% (3,751)

Italian providers — 42.9% · Italian cloud — 4.0% · self-run — 3.6% · European (non-Italian) — 0.5%

AWS and Oracle matter enormously elsewhere: in the national cloud program. Different service, same jurisdiction problem.

National Security What?!?

Categoria ▲	Ente	Dominio	Provider email	Sovranità	Evidenza
Forze di Polizia	Ministero dell'Interno - Dipartimento della Pubblica Sicurezza - Polizia di Stato	poliziadistato.it	Microsoft 365	us USA (CLOUD Act)	MX record (poliziadistato-it.mail.protection.outlook.com) matches Microsoft ⚠ Riporta un errore

Categoria ▲	Ente	Dominio	Provider email	Sovranità	Evidenza
Forze di Polizia	Arma dei Carabinieri	carabinieri.it	Google Workspace	us USA (CLOUD Act)	MX record (smtp.google.com) matches Google ⚠ Riporta un errore

Categoria ▲	Ente	Dominio	Provider email	Sovranità	Evidenza
Autorità Indipendente	Agenzia per la Cybersicurezza Nazionale	acn.gov.it	Microsoft 365	us USA (CLOUD Act)	MX record (acn-gov-it.mail.protection.outlook.com) matches Microsoft ⚠ Riporta un errore

Categoria ▲	Ente	Dominio	Provider email	Sovranità	Evidenza
Ministero / PCM / Avvocatura Stato	Ministero della Difesa	difesa.it	Infrastruttura autonoma	π Self-hosted	MX (mx.difesa.it) is self-hosted ⚠ Riporta un errore

02 · continues

Following the money

The same question asked of the contracts, not of the DNS

What we actually did

Every public contract in Italy since 2024

3,745,883 contract notices (CIG) pulled from the national public-contracts database, then filtered down in stages — each stage published, each stage reproducible.

85.9% excluded with certainty: not ICT at all. What survives is the part that needs judgement.

Certain cloud spending: 4,537 contracts, €1.21bn. Plus €0.72bn awarded in-house.

The hard part is not the sum. It is the ceiling. Framework agreements and concessions publish a maximum, not what was spent. We separated the two: €58.2bn in scope, of which €14.4bn still uncertain — and we say which 79 contracts they are.

Method, code and intermediate files are public. The uncertain stays labelled uncertain.

Two instruments, two methods, one answer

The result that matters

43.3%

who operates the email
of 22,922 public bodies,
read from public DNS records

45%

where the cloud money goes
of €1.21bn in certain cloud contracts,
read from awarded public contracts

Different sources, different methods, independently built — and they land in the same place. Neither confirms the other; together they make the number hard to dismiss.

What stops anyone from counting

Eighteen defects found, seventeen written up for the authority

1,282 placeholder tax codes in the contracting-authority register: bodies recorded as «CFAVCP-…» instead of an identifier. You cannot aggregate what you cannot name.

20 public bodies out of 617 have published the procurement-plan data they are required to publish.

The ceiling problem, quantified: framework agreements and concessions publish a maximum. Read naively, Italian public ICT looks like €113bn. Read with the ceilings separated, €58.2bn.

National cloud programme: €4.38bn committed in the public database — against €0.79bn of revenue reported for 2023-25 in the company's own accounts. We report both and label which is which.

Each defect is written as a problem with a proposed remedy. None of it requires new law — only that existing obligations be met.

03

Why jurisdiction beats geography

The legal core

The CLOUD Act, in one sentence

Legal

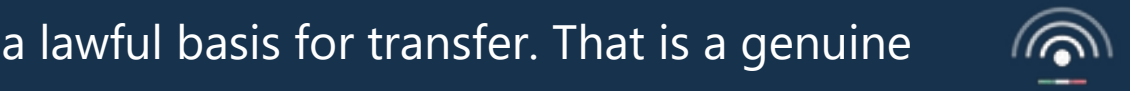
A US provider must produce data in its **possession, custody or control** — **regardless of where that data is stored**. 18 U.S.C. §2713.

Storing data in Milan does not change who can be compelled to hand it over. The obligation attaches to the company, not to the disk.

Add **FISA 702** for foreign-intelligence collection, and gag orders that can forbid telling the customer it happened. The Italian body may never learn that it occurred.

This is why the map classifies by jurisdiction of the operator, not by datacentre location.

GDPR Article 48 says a foreign order is not, by itself, a lawful basis for transfer. That is a genuine conflict of laws — and the provider sits on both sides of it.



FISA Section 702 — the part that fits us exactly

Legal — the second instrument

The CLOUD Act is about stored records in criminal process. **Section 702 is about foreign intelligence**, and its scope is the uncomfortable one for us.

It targets non-US persons reasonably believed to be located outside the United States. An Italian municipality, its staff and its citizens are precisely that category — not an edge case, the intended one.

It compels **US electronic communication service providers** to assist. There is no individual warrant naming your city council: collection runs under programmatic certifications, with directives to the provider.

And the provider may be barred from telling you. The absence of a notification is not evidence that nothing happened.

What Microsoft said under oath

The admission

In June 2025, before a French Senate committee, Microsoft's representative was asked whether the company could guarantee that data held in its sovereign French cloud would never be handed to US authorities.

«Non posso garantirlo.» — I cannot guarantee it.

That is not an activist's claim. It is sworn testimony from the vendor, and it is the shortest available summary of everything on the previous slide.



04

The geopolitical layer

Dependency is not a technical property. It is leverage.

Why this is a security question, not a procurement one

Geopolitics

Dependency is leverage. Infrastructure a foreign executive can throttle, price, deprecate or condition is a policy instrument pointed at you — whoever currently holds it and however friendly they are today.

Europe wrote the rule, then removed it. The EU cloud certification scheme (EUCS) once carried immunity-from-extraterritorial-law criteria at its highest level. They were dropped in 2024 — and Italy was among the states that did not defend them.

Someone did write it down. France's SecNumCloud requires the provider to be established in the EU, to be under European capital control, and to be administered from the EU. Three conditions, verifiable, pass or fail.

And private buyers act on it. Airbus, which asked the EU for that criterion, then used it in its own tender and moved critical applications to a European provider.



France wrote it down: SecNumCloud 3.2

The measure that actually measures

ANSSI's qualification referential does something no Italian document does: it states **conditions on the provider itself**, not on the technology.

Establishment in the European Union.

European capital control — a cap on non-EU holdings.

Administration and operation of the service from the EU.

Three requirements. Verifiable. A provider either satisfies them or does not — there is no configuration that makes a non-compliant company compliant.

This matters beyond France. It is the template the European debate keeps returning to, and the reference point for the Cloud and AI Development Act now under discussion, whose highest levels would require that no third country hold effective control over design, development and maintenance.



EUCS High+: the criterion Europe wrote, then dropped

The letter, and who signed it

The European cloud certification scheme once carried immunity from extraterritorial law at its highest level. **It was removed in 2024.**

An open letter asked the Union to restore a criterion protecting the most sensitive data **«from access or operational disruption arising from non-European extraterritorial laws»**. **62 organizations** signed. The campaign site declares it is run by Airbus's Brussels office.

Five Italian signatories: Leonardo · Fincantieri · Generali · Telecom Italia · Aruba.

Read that against the previous section. Leonardo and TIM are two of the four companies that hold the national cloud concession. The same names asking Europe for immunity criteria are inside the programe that does not impose them.

Airbus later applied the criterion in its own tender and moved critical applications to a European provider.

05

Why it belongs at a security conference

Threat models



The cybersecurity case

Relevance

Lawful access is a threat model. If your adversary model excludes the operator and the state that can compel it, your model is incomplete — and for a public body it is the one actor able to obtain everything, silently and legally.

Concentration is systemic risk. Two vendors carry 43% of Italian public email. A single outage, breach or policy change propagates across the whole state at once.

You cannot do incident response on what you cannot see. Logs, retention and forensic access are set by contract; the responder's authority ends where the provider's console begins.

Supply chain and NIS2. Public bodies must assess supplier risk. Jurisdiction of the operator is a supplier risk — and today it is absent from almost every Italian risk assessment.

This map is free reconnaissance — for everyone. It is public DNS: attackers already have it. The only question is whether defenders do.

06

Sovereignty washing

The arguments used on technicians and decision makers by US BigTech

How the trick works, before the examples

The pattern

Every one of these measures is **real engineering**. None of them is fake. That is exactly what makes the move effective.

The sleight of hand is always the same: **a genuine technical control is offered as an answer to a legal question.**

Encryption, key custody, enclaves and policy constraints change *how hard* it is to reach the data. **They do not change who is legally obliged to try when compelled.** A company subject to US law remains subject to US law after you enable the feature.

SOVEREIGNTY WASHING

Measure 1 — Data residency

THE CLAIM

«Your data never leaves the European Union.»

EU Data Boundary, EU regions, in-region processing and storage commitments.

WHAT IT ACTUALLY DOES

Answers a geographic question nobody asked.

18 U.S.C. §2713 attaches to the company's possession, custody or control — not to the location of the disk.

A US provider with data in Milan is still a US provider served with a US order.

Residency is necessary for other reasons. It is not sovereignty, and it never was.



SOVEREIGNTY WASHING

Measure 2 — Customer-managed keys (BYOK / HYOK / EKM)

THE CLAIM

«You hold the keys. We cannot read your data without them.»

External key stores, hold-your-own-key, key access logging and revocation.

WHAT IT ACTUALLY DOES

Better than provider-managed keys — genuinely.

But data must be decrypted to be processed, and processing happens on their silicon, in their memory, under their control plane.

If the key store sits in the same legal estate, it is reachable by the same order.

Revocation is a kill switch, not a shield: it protects future access, not the session in flight.

Key custody moves the problem. It does not remove the party able to be compelled.



SOVEREIGNTY WASHING

Measure 3 — Confidential computing

THE CLAIM

«The operator cannot read your data, even in memory.»

Hardware enclaves — Intel TDX, AMD SEV-SNP — with remote attestation.

Microsoft ships a whole Confidential tier on this basis; the PSN catalogue sells it as sovereignty.

WHAT IT ACTUALLY DOES

The strongest measure on offer, and still not an answer.

ANSSI's technical position is explicit that it does not remove exposure to extraterritorial jurisdiction.

It protects against the operator reading RAM. It does not govern the control plane, the attestation service, the images you are allowed to run, or a court order to the parent.

And note the wording: enclaves do NOT «process encrypted data». Inside the enclave the data is plaintext to the CPU; the memory around it is encrypted.

Protecting data from the operator is not the same as protecting it from the operator's government.



Homomorphic encryption and MPC genuinely compute on ciphertext — and are not what these products ship for general workloads.

SOVEREIGNTY WASHING

Measure 4 — Operator access control

THE CLAIM

«No engineer touches your data without your approval.»

Customer Lockbox, Operator Access Control, just-in-time access, approval workflows, session recording.

WHAT IT ACTUALLY DOES

Governs routine support access by employees.

Legal process does not arrive as a support ticket, and is not presented to you for approval.

Where a gag order applies, the mechanism that would have shown you the access is precisely the one that stays silent.

It is an insider-risk control. It was never a legal-process control.



SOVEREIGNTY WASHING

Measure 5 — A separate European legal entity

THE CLAIM

«A European company, European staff, European governance.»

Dedicated EU subsidiaries for sovereign cloud offerings.

WHAT IT ACTUALLY DOES

Corporate separation inside the same ultimate parent is not legal separation.

AWS European Sovereign Cloud GmbH: the notarised German shareholder list shows a single shareholder at 100% — A100 ROW, Inc., Wilmington, Delaware.

The structure is real. The question is what the parent can be compelled to do with what it controls.

We read the notarised register so the claim does not rest on anyone's press release.



SOVEREIGNTY WASHING

Google

THE CLAIM

Assured Workloads — sovereignty controls.

Sovereign Controls «by Partners», operated locally.

Key Access Justifications: you see, and can deny, every key access request.

Data residency and personnel-location policies.

WHAT IT ACTUALLY DOES

Assured Workloads is a set of organization policy constraints — real, but configuration, not immunity.

The partner operates; Google still supplies and controls the platform.

KAJ is the strongest control — and it governs the technical path, not a court order to the parent.

Residency again answers the wrong question.

The most honest of the four — and still not a jurisdictional answer.

27.7% of Italian public bodies — 6,374 — run their official email on Google Workspace. The largest single dependency.

SOVEREIGNTY WASHING

Amazon Web Services

THE CLAIM

European Sovereign Cloud, a separate EU entity with EU staff.

Nitro System: «AWS operators cannot access customer data.»

Nitro Enclaves for isolated processing.

External key management, audited by third parties.

WHAT IT ACTUALLY DOES

The German entity is 100% owned by A100 ROW, Inc., Wilmington, Delaware — we have the notarised shareholder list.

Nitro System and Nitro Enclaves are different things; the System-level claim is regularly answered with Enclaves documentation.

Corporate separation inside the same ultimate parent does not create legal separation.

Audits verify the mechanism works as described — not that the company is beyond reach.

Ownership chain, from the notarised German commercial register: sole shareholder, 100%, Delaware.

SOVEREIGNTY WASHING

Oracle

THE CLAIM

Alloy — a cloud region you operate yourself.

Operator Access Control: the customer approves operator sessions.

Exadata Cloud@Customer — hardware on your own premises.

«Your realm, your control plane.»

WHAT IT ACTUALLY DOES

The realm runs Oracle's software and depends on Oracle for updates and lifecycle.

Approval covers routine operator sessions, not the vendor's legal obligations.

Hardware on-premises still runs a stack you do not control and cannot fork.

In the PSN catalogue, not all services sit in PSN datacentres — some remain the vendor's.

Physical location is the most persuasive illusion of the four, and the least relevant.

Also relevant: none of these vendors accepts the three SecNumCloud requirements.



SOVEREIGNTY WASHING

Microsoft

THE CLAIM

EU Data Boundary — data stays in Europe.

Customer Lockbox and approval workflows.

«Sovereign Cloud», operated with local partners.

Customer-managed keys.

WHAT IT ACTUALLY DOES

Residency ≠ jurisdiction: §2713 follows the company.

Lockbox governs support access, not legal process.

Partner operation leaves the control plane and the software with Microsoft.

Keys held in the same legal estate can be compelled.

Their own witness, under oath, June 2025: «I cannot guarantee it.»

The only one that deserve a merit: Effective sovereign deployment in China and France (as a Cloud software provider)

18.3% of Italian public bodies — 4,203 — run their official email on Microsoft 365.

And this is where the national cloud programme lands

The Italian case, in one slide

PSN — Polo Strategico Nazionale. Italy's answer: consolidate public administration onto a national strategic hub. The concession is held by a consortium of four Italian companies — **CDP Equity, TIM (lead), Sogei and Leonardo**.

Give it its due. AgID found 95% of the public server rooms it surveyed deficient in security and reliability. Consolidating them was necessary and long overdue, and the programme genuinely improves on the basement datacentre.

But on sovereignty it is as far from the goal as it gets. The cloud services sold through it are Microsoft, Google, AWS and Oracle — resold by Italian companies with no sovereignty leverage over any of them, reportedly on intermediation-level margins.

«Sovereignty» appears 31 times in the commercial documents and 0 times in the 86 pages of the concession and technical specifications. None of SecNumCloud's three requirements is imposed on any supplier.



What we are asking public bodies to do

Actionable

Know your own position. Every body has a page on mxmap.it. Most have never looked.

Put jurisdiction in the risk assessment. It is a supplier risk under NIS2, and it is almost universally missing.

Write it into the tender. The instrument that reaches a foreign provider is not sanctions or golden power — it is the procurement requirement. France proved it can be drafted.

Self-hosting and free software are a real option for a large share of these workloads, and 13.5% of Italian bodies already do it.

Contribute

The measurement is done. The hard part is what follows.



MXMap Italia

https://mxmap.it

Interactive software mapping

Observatory

osservatorio.mxmap.it

Papers, briefs, roadmap

Telegram

t.me/+Ot-M_g0dkh1kMGI0

Join the community

GitHub

github.com/mxmap-it

Software, data, issues

Technical · Legal · Political · Dissemination

Fabio Pietrosanti (naif) — fabio@pietrosanti.it — Hermes Center · onData · Copernicani